IS09 — Vulnerability Management Policy

[Company] IIoT Platform

Project name: [Company] Security Policies	Status: Active
Date: [Date]	Version: 1.0
Author: [Author Name]	Reviewer: [Reviewer Name]

Versions

Revision	Date	Author	Description
1.0	[Date]	[Author Name]	Initial release

Related Standards, Policies and Processes

- IS01 - [Company] Information Security Policy
- [Company] Security Verification and Testing Process (IEC 62443-4-1)
- [Company] Software Deployment Security Process (IEC 62443-4-1)
- [Parent Company] - Software/Systems Development Life Cycle (SDLC) Policy

Definitions and Terms

Definitions and terms used in this policy follow the SANS Institute Glossary of Security Terms.

Overview

This policy seeks to enhance the security and resilience of [Company] systems, protect sensitive information, and maintain compliance with industry standards and regulatory requirements.

Through vulnerability scanning, penetration testing, and vulnerability remediation processes, the aim is to identify and address security weaknesses in a timely manner, minimize potential threats, and safeguard the confidentiality, integrity, and availability of our data and networks.

Purpose

This policy establishes guidelines, principles and best security practices that govern security requirements and processes for vulnerability management. It serves as a roadmap to align teams, streamline workflows, and achieve the goals of Zero Trust by minimizing the attack surface and limiting vulnerabilities in the [Company] platform.

Scope

All employees, contractors, consultants, temporary and other workers of [Company] working on the [Company] IIoT Platform must adhere to this policy. This policy applies to the [Company] platform and its components.

This policy specifies requirements for managing vulnerabilities in [Company] platform products and the IT environment.

Policy

Vulnerability Management

[Company] shall maintain a comprehensive Vulnerability Management System to identify, track, and manage vulnerabilities and weaknesses across the platform and its products.

The system shall continuously assess the security posture of organizational assets by measuring the state of known vulnerabilities and weaknesses, and by monitoring the effectiveness of the patching and remediation processes.

System configurations and component versions shall be evaluated against:

- recognized security standards (e.g., CIS Benchmarks, NIST),
- vendor security advisories,
- publicly known Common Vulnerabilities and Exposures (CVE),
- Common Weakness Enumerations (CWE), and
- industry security best practices.

The Security Team is responsible for maintaining appropriate tools, platforms, and processes designed to detect, assess, and monitor vulnerabilities and weaknesses.

Development teams are responsible for timely remediation of identified vulnerabilities and weaknesses in their respective codebases and products, in accordance with defined SLAs and risk severity.

Penetration Testing and External Audits

[Company] shall maintain a structured and proactive penetration testing and security assessment program as part of its overall Vulnerability Management strategy. This program ensures that the security

posture of [Company]'s platforms, applications, and infrastructure is regularly evaluated against evolving threats, vulnerabilities, and attack techniques.

Internal Penetration Testing

[Company] conducts internal penetration testing at regular intervals within its product development lifecycle.

Specifically, internal penetration tests are conducted every two release cycles, targeting both infrastructure and application components.

These tests simulate realistic attack scenarios and help validate the effectiveness of implemented security controls, as well as the remediation of previously identified vulnerabilities.

External Penetration Testing and Security Assessments

[Company] engages independent, qualified third-party security vendors to perform at least one formal penetration test or security assessment per calendar year.

These assessments may include black-box, gray-box, or white-box testing, depending on the agreed scope and risk profile of the environment or product.

Reports from external assessments are reviewed by the Security Team, and all validated findings are triaged and remediated in accordance with defined SLAs and severity levels.

Customer-Initiated Audits and Assessments

[Company] supports security audits or assessments initiated by customers, subject to the following conditions:

A mutual Non-Disclosure Agreement (NDA) must be executed before any audit or assessment is conducted.

Scope, timing, and access requirements of customer audits must be mutually agreed upon in advance.

[Company] will provide reasonable support during such audits and work with customers to address valid findings in line with internal remediation processes and contractual commitments.

Documentation and Reporting

All penetration testing and assessment activities, including planning, execution, findings, and remediation, shall be appropriately documented (reports or questionnaires).

Summary reports and evidence of remediation actions shall be retained by the Security Team and made available to internal stakeholders or external parties (e.g., auditors, customers) upon request and under appropriate confidentiality agreements.

Summaries must not contain technical details of identified vulnerabilities and should be limited to a general description of the risk.

SLAs

[Company] shall prioritize and remediate vulnerabilities based on their severity and impact on the platform, products, and services. The following remediation timeframes apply to vulnerabilities identified in internally developed systems and products:

Severity	Remediation Target	Notes
Critical	Within 48 hours	Treated as hotfixes. Immediate mitigation may also be required.
High	Within 2 weeks	Included in expedited releases or patches.
Medium	Next scheduled release	Remediated as part of the normal development cycle.
Low	Next scheduled release	Addressed as part of ongoing improvements.
Informational	As needed	No immediate action required; monitored.

Remediation timelines begin from the date of validation and triage by the Security Team.

Vulnerabilities identified in third-party components, libraries, services, or platforms shall be managed based on the respective vendor's or provider's security policies and SLAs.

- Where applicable, [Company] shall track third-party vulnerabilities and ensure vendors comply with contractual obligations.
- Detailed handling of third-party vulnerabilities is covered in IS06 - Third-Party Supplier Security Policy.

Policy Compliance

Compliance Measurement

The Security Team will verify compliance with this policy through various methods, including but not limited to internal and external audits and feedback.

Exceptions

Any exception to the policy must be approved by the Security Team in advance.

Non-Compliance

An employee found to have violated this policy may be subject to disciplinary action.